Trabajo Práctico Integrador

n1krov, Juani, Pollo y Chipancho

3 de noviembre de 2026

Índice

1. PARTE 1 DEL TP: Aplicación de RRHH (Págs. 2 a 7) 2
1.1. Punto A: Reestructuración del Área de TI (El modelo RUO + Outsourcing) 2
1.2. Punto B: Descripción y Análisis de Cargo (DyAC) del Director de TICs (Págs. 5 a 7) . . 3

2. PARTE 2 DEL TP: Aplicación de SI/TI - Rendimiento y Capacidad (Págs. 7 a 11) 4
2.1. Punto A: Nivel de Planificación de la Capacidad según Molero 4
2.2. Punto B: Las 3 UPN elegidas y los 2 Gráficos de Carga 4

3. PARTE 3 DEL TP: Seguridad de SI/TI y Plan de Contingencia (Págs. 11 a 44) 5
3.1. Fase I: Identificación de Riesgos (En orden estricto: Activos → Vulnerabilidades → Amenazas) 5
3.2. Fase II: Análisis del Riesgo (Cálculo del ALE) 5
3.3. Fase III: Manejo de Riesgos (Estrategias, Líneas de Defensa, Políticas y Costo-Beneficio) 6
3.4. Fase IV: Plan de Contingencia y Recuperación ante Desastres (DRP - Lardent) 6

4. LAS 4 "PREGUNTAS TRAMPA" QUE TE PUEDE HACER SORIA OJEDA MAÑANA SOBRE TU TP 7

¡Tu Trabajo Práctico está **excelente** y muy completo! El caso de estudio de ustedes es la **Dirección de Vialidad Provincial del Chaco (DVP)** y gira en torno a tres sistemas clave que vienen del TP1:

1. **ERP Vial Integral** (desarrollo *In-House*, con dos módulos críticos: **Certificaciones de Obra** y **Fondo Vial**).
2. **SIG GeoVial** (sistema de mapas e información geográfica con *PostGIS/GeoServer*).
3. **SiCC Móvil** (app en *tablets* para el despacho de combustible en campamentos viales y en las 5 Delegaciones Zonales).

Acá tenés la **guía maestra paso a paso de todo tu TP**, conectada con la teoría y con las **preguntas exactas de defensa** que les va a hacer mañana la Ing. Soria Ojeda:

---

1. PARTE 1 DEL TP: Aplicación de RRHH (Págs. 2 a 7)

1.1. Punto A: Reestructuración del Área de TI (El modelo RUO + Outsourcing)

- **Diagnóstico actual (*AS-IS*):** Hoy es un simple «Departamento de Informática» con **estructura tradicional** orientada solo a soporte técnico básico (apagar incendios), donde Desarrollo está subordinado a Servidores. No tiene peso político ni capacidad para crear el ERP ni el GeoVial.
- **Propuesta (*TO-BE*):** Se transforma y eleva jerárquicamente a **Dirección de TICs (Clase XIX / Nivel Superior)**, reportando directamente a la máxima autoridad (el **Administrador General** de Vialidad).
- **Justificación teórica con el modelo RUO (Robson):**
    1. **UBICACIÓN → Centralizada con Prestación Externa (*Outsourcing*) de Infraestructura:**
        - *¿Por qué Centralizada?:* Todas las decisiones estratégicas, políticas de TI y prioridades se retienen en la Dirección de TICs en Resistencia, **sin delegar ni transferir autoridad a las 5 delegaciones zonales**.
        - *¿Cómo se aplica?:* Mediante el concepto de **Supercentros**. En vez de tener servidores físicos repartidos en el interior, se centraliza todo alojando los servidores (*IaaS - Infraestructura como Servicio*) en el **Data Center de ECOM Chaco** (tercerización), pero manteniendo la gobernanza y administración lógica centralizada en la DVP.
    2. **ROL → Transición evolutiva hacia «Fábrica de Soluciones y Datos»:**
        - Pasa de ser un "taller de reparaciones" a un **Proveedor de Servicios Internos** (Modelo de Servicio) y luego a una **Fábrica de Soluciones y Datos** (Modelo de Participación / Ventaja Estratégica), enfocada en desarrollar *In-House* el ERP Vial y procesar mapas en GeoVial.
    3. **ORGANIZACIÓN → Departamentalización por Bases de Datos, Proyectos y Operaciones:**

  - Debajo de la Dirección de TICs crearon **3 Departamentos** (nivel táctico/gerencia media) y **6 Divisiones** (primera línea):
    * **1. Dpto. de Gestión de Datos y Analítica (Área *Core*):** Tiene la *Div. SIG y Datos Espaciales* (*PostGIS/GeoServer*) y la *Div. Inteligencia de Negocios (BI).* (Enfoque de estructura de Bases de Datos y Centro de Información).
    * **2. Dpto. de Desarrollo de Soluciones («Fábrica de Software»):** Tiene la *Div. Arquitectura y Programación* (Programadores Full-Stack para ERP y SiCC) y la *Div. Análisis Funcional* (Relevamiento y QA/Testing). *(¡Ojo acá para Auditoría!: separaron programación de testing/análisis cumpliendo con la segregación de funciones).*
    * **3. Dpto. de Operaciones y Servicios Internos:** Controla el contrato con ECOM, la seguridad y el soporte. Tiene la *Div. Infraestructura y Ciberseguridad* y la *Div. Mesa de Ayuda y Soporte* (incluye técnicos y chofer de logística).

- **Contrato de *Outsourcing* (SLA) con ECOM Chaco:**
  - Como el software es *In-House* (por soberanía tecnológica), **solo tercerizan el alojamiento físico (IaaS)**. El SLA exige **4 puntos**:
    1. **Disponibilidad (*Uptime*) del 99,5%** en horario pico administrativo (07:00 a 14:00 hs).
    2. **Escalabilidad Elástica:** Aumentar RAM y CPU de las máquinas virtuales en **menos de 24 hs** ante picos.
    3. **Seguridad y Backups: RPO = 12 horas** (copias automáticas de PostgreSQL cada 12 hs; es lo máximo de datos que aceptan perder) y **RTO = 4 horas** (tiempo máximo que tiene ECOM para restaurar el ERP tras una caída catastrófica).
    4. **Penalizaciones económicas:** Bonificaciones o multas si se cae GeoVial/ERP a fin de mes e impide certificar obras.

1.2. Punto B: Descripción y Análisis de Cargo (DyAC) del Director de TICs (Págs. 5 a 7)

Usaron el enfoque de **Gestión por Competencias de Martha Alles**:

- **I. Descripción (Intrínseco - 4 Atribuciones):** 1) Definir políticas tecnológicas, 2) Liderar a los 3 Jefes de Departamento, 3) Gestión estratégica del cliente interno (Operaciones, Zonas, Finanzas, RRHH), y 4) Desarrollo del talento (selección, evaluación y planes de carrera).
- **II. Análisis / Especificación (Extrínseco - Trilogía de Competencias en Grados A y B):**
  - **1. Competencias Cardinales** (exigidas a toda la DVP, Grado A): *Adaptabilidad a los cambios, Compromiso, Ética y sencillez.*
  - **2. Competencias Específicas Gerenciales** (por ser «líder de líderes», Grado A): *Liderazgo Ejecutivo, Visión Estratégica, Liderazgo para el Cambio.*
  - **3. Competencias Específicas por Área** (propias de TICs): *Manejo de Crisis* (Grado A), *Influencia y Negociación* (Grado B) y *Credibilidad Técnica* (Grado B).

- **III. Evaluación y Detección de Brechas:** Se hace un *Inventario de Competencias* para medir la brecha (*gap*) entre el grado requerido (ej. A) y el que trae el postulante (ej. C), usando **Entrevistas por Incidentes Críticos (BEI)** y **Planes de Codesarrollo** (tutorías).

---

2. PARTE 2 DEL TP: Aplicación de SI/TI - Rendimiento y Capacidad (Págs. 7 a 11)

2.1. Punto A: Nivel de Planificación de la Capacidad según Molero

- **Situación Actual (*AS-IS*):** Estancada en un **Nivel de Componente (Operativo) / Sistema (Táctico)** (Niveles 0 y 1 de Molero). Es **reactiva** («apagar incendios»: si *Stock* o *Viaticar* anda lento, le compran más RAM a esa PC suelta) y **sin visión transversal** (silos aislados, y el sistema de obras estaba tercerizado en "Consorcio"). Si hoy instalan el mapa GIS GeoVial, la red colapsa.
- **Situación Futura (*TO-BE*):** Salto al **Nivel de Negocio (Estratégico - Nivel 5 de Molero)**. Ya no se compran PCs sueltas; se planifican las VMs, PostgreSQL y GeoServer según las **variables del negocio (UPN)**.

2.2. Punto B: Las 3 UPN elegidas y los 2 Gráficos de Carga

Recuerden que la **UPN (Unidad de Predicción Natural)** es la variable del negocio (no técnica) que estresa el hardware:

1. **UPN 1: Certificaciones de Obra (ERP):** Expediente digital de avance físico-financiero de una ruta. Más obras = más archivo en **Disco**. En los días de cierre contable a fin de mes, cruzar datos y curvas de inversión estresa **CPU y RAM**.
    - **Gráfico A (Comportamiento mensual - Días 1 al 30):** Es una **Carga Cíclica o Transaccional Concentrada**. Del día 1 al 20 es plana/valle (~10%); del 21 al 25 sube; y **del día 25 al 30 tiene un pico máximo extremo (100%)** porque todos los inspectores y contratistas cargan certificaciones para cobrar antes de fin de mes.
2. **UPN 2: Mapas / Inventario Espacial (SIG GeoVial):** Capas vectoriales y polígonos de rutas. Cada km nuevo de ruta demanda **Disco**, y cada vez que un ingeniero pide renderizar el mapa en pantalla (sistema casi interactivo) estresa **RAM y procesamiento gráfico**.
3. **UPN 3: Ensayos de Laboratorio:** Muestras de asfalto, suelo y hormigón. Crece por km de obra (demanda **Disco** a largo plazo para auditar garantías de obra) y al cruzar cientos de registros estadísticos para emitir certificados estresa la **CPU**.
    - **Gráfico B (Comportamiento diario - 00:00 a 24:00 hs):** Es una **Carga Interactiva con Picos de Procesamiento (*Batch-like*)**. De 07:00 a 10:00 hs es media-baja (~30%) porque los técnicos están haciendo pruebas físicas en el laboratorio; **de 10:30 a 12:30 hs tiene el pico máximo (100%)** cuando vuelven al escritorio, cargan todo junto y el Director genera los Certificados de Calidad en PDF; después de las 13:00 hs cae a cero.

---

3. PARTE 3 DEL TP: Seguridad de SI/TI y Plan de Contingencia (Págs. 11 a 44)

Aplicaron las **4 Etapas de Administración de Riesgos (Robson/Lardent)** cruzadas con la norma **IRAM-ISO/IEC 27001**:

3.1. Fase I: Identificación de Riesgos (En orden estricto: Activos → Vulnerabilidades → Amenazas)

1. **Activos:** *Hardware* (VMs en ECOM, servidores locales, red/firewalls, PCs en 5 delegaciones, Tablets SiCC Móvil), *Software* (ERP Vial, SIG GeoVial, PostgreSQL, clientes VPN) y *Datos* (Certificaciones, cartografía, despachos de combustible, padrón).
2. **Vulnerabilidades:** Accesos remotos sin cifrado en delegaciones, baja señal/conexiones inseguras en zonas rurales para tablets SiCC, falta de capacitación en ciberseguridad (vulnerables a *phishing*) y alta concentración de datos en un único proveedor (ECOM).
3. **Amenazas (Matriz Físicas/Lógicas vs. Accidentales/Deliberadas):**
   - *Física Accidental:* Incendio, inundación o corte eléctrico prolongado.
   - *Física Deliberada:* Robo/hurto de tablets SiCC en campamentos; sabotaje de cables.
   - *Lógica Accidental:* Errores humanos al cargar certificaciones; *bugs* del ERP; desconfiguración de VPN.
   - *Lógica Deliberada: Ransomware*, ataques DoS/DDoS, *Hacking*/fraude interno en Fondo Vial o certificaciones, *Phishing* y Virus.

3.2. Fase II: Análisis del Riesgo (Cálculo del ALE)

Usaron las dos fórmulas de Robson:

$$\text{Frecuencia de pérdida} = \text{Probabilidad de agresión} \times \text{Probabilidad de éxito}$$

$$\text{Pérdida Esperada Anual (ALE)} = \text{Pérdida Potencial (\$)} \times \text{Frecuencia de pérdida}$$

Valuaron **7 pares Activo–Amenaza** (ordenados de mayor a menor riesgo):

1. **BD Certificaciones / Ransomware:** $60\% \times 75\% = 45\% \times \$25\text{M} = \$\mathbf{11.250.000}$ (*Crítico* - el mayor riesgo).
2. **Fondo Vial / Hacking o Fraude interno:** $35\% \times 50\% = 17,5\% \times \$40\text{M} = \$\mathbf{7.000.000}$ (*Crítico*).
3. **SIG GeoVial / Virus o Corrupción:** $40\% \times 45\% = 18\% \times \$12\text{M} = \$\mathbf{2.160.000}$ (*Alto*).
4. **Estaciones de Trabajo / Phishing:** $70\% \times 50\% = 35\% \times \$6\text{M} = \$\mathbf{2.100.000}$ (*Alto*).
5. **Tablets SiCC Móvil / Hurto en campo:** $65\% \times 60\% = 39\% \times \$4,5\text{M} = \$\mathbf{1.755.000}$ (*Moderado*).
6. **Red VPN Delegaciones / Caída o Interceptación:** $50\% \times 40\% = 20\% \times \$8\text{M} = \$\mathbf{1.600.000}$ (*Moderado*).

7. **Instalaciones Sede Central y Delegaciones / Incendio-Inundación-Corte:** $\$900.000$ (*Bajo* - agregado en el punto 3.8 para sustentar el caso de catástrofe).

- **Total Pérdida Esperada (ALE) sin controles:** $\$26.765.000$ ($\$25.865.000$ de los primeros 6 + $\$900.000$ de instalaciones).

3.3. Fase III: Manejo de Riesgos (Estrategias, Líneas de Defensa, Políticas y Costo-Beneficio)

- **Regla para elegir la Estrategia:**
  - *Crítico (*$> \$7M$*):* **Reducir + Transferir** (en BD Certificaciones se reduce con backups 3-2-1 inmutables/EDR y se transfiere con SLA de ECOM y seguro de ciberriesgo). **¡Excepción clave!:** En **Fondo Vial (**$\$7$**M)** eligieron **solo Reducir** (RBAC, segregación de funciones donde quien carga no autoriza, 2FA y *logs* inalterables) porque **la responsabilidad sobre el fraude con fondos públicos es indelegable y no se puede transferir**.
  - *Alto (*$\$2M - \$7M$*):* **Reducir** (en GeoVial con separación Desarrollo/Testing/Producción y *checksum*; en Phishing con capacitación obligatoria, campañas simuladas y 2FA).
  - *Moderado (*$\$1M - \$2M$*):* **Transferir + Reducir** (en Tablets SiCC: seguro técnico para el equipo físico + MDM con geolocalización y borrado remoto [*remote wipe*] para los datos; en Red VPN: túneles IPsec/TLS + enlace alternativo 4G/5G + SLA con proveedor).
  - *Bajo (*$< \$1M$*):* **Prevenir + Transferir** (en Instalaciones: detectores de humo, UPS/grupo electrógeno de 8 hs, llevar servidores a ECOM y seguro de incendio).
- **Evaluación Costo-Beneficio (Pág. 29-30):**
  - Pérdida Esperada Actual: $\$26.765.000$
  - Inversión Anual en controles: $\$9.500.000$
  - Pérdida Esperada Residual (con controles): $\$9.990.000$
  - **Beneficio Neto Anual para la DVP:** $\$7.275.000$ (porque gastar $\$9,5$M baja la pérdida en $\$16,775$M).

3.4. Fase IV: Plan de Contingencia y Recuperación ante Desastres (DRP - Lardent)

- **¿Cuándo se activa el DRP? (5 niveles de gravedad - Pág. 32):**
  - Los Niveles 1 (*Inconveniente*) y 2 (*Interrupción moderada*, ej. robo de 1 tablet o caída de VPN < 4 hs) los resuelve la **Mesa de Ayuda**.
  - **El DRP y el Comité de Crisis se activan a partir del Nivel 3 (*Evento significativo*)**, Nivel 4 (*Desastre*: ej. Ransomware en BD o caída de ECOM > 4 hs) y Nivel 5 (*Catástrofe*: incendio/inundación total).
- **Prioridades de Recuperación de los Sistemas (Pág. 37 - según tolerancia):**
  1. **1º Conectividad, VPN, directorio y firewall** (*Crítico habilitante* - Tolerancia nula - **RTO: 2 hs**). Va primero porque sin red no anda nada.

2. **2º BD PostgreSQL + ERP (Certificaciones y Fondo Vial)** (*Crítico* - **RTO: 4 hs / RPO: 12 hs**). Va segundo por los plazos legales perentorios y multas del Tribunal de Cuentas.
3. **3º SiCC Móvil (Combustible)** (*Sensible* - **RTO: 8 hs / RPO: 24 hs**). Tolera más porque mientras tanto los campamentos despachan con **planillas en papel**.
4. **4º SIG GeoVial** (*Vital* - **RTO: 24 hs**) y **5º Correo/Ofimática/Mesa de Ayuda** (*Vital* - **RTO: 24 hs**).
5. **6º Tableros BI y portal web** (*No crítico* - **RTO: 72 hs**).

- **Sitios Alternativos (Pág. 38):**
  - *Para los servidores (Hardware):* Segundo centro de datos de ECOM Chaco configurado como **Warm site (réplica en caliente)**, que levanta dentro del RTO de 4 hs.
  - *Para las personas (Puestos de trabajo):* Edificio de la **Delegación Zonal Resistencia** (15 puestos propios con energía y red, costo cero de alquiler, listo en < 8 hs).
- **Orden de Reprocesamiento al volver a la normalidad (Pág. 37-38):**
  - 1º Certificaciones de obra que vencen en los próximos 5 días $\rightarrow$ 2º Órdenes de pago del Fondo Vial $\rightarrow$ 3º Planillas en papel de combustible (SiCC) $\rightarrow$ 4º Capas de GeoVial $\rightarrow$ 5º RRHH $\rightarrow$ 6º BI. Al terminar cada etapa se firma un **Acta de Conciliación** entre el *Responsable Funcional (Jefe de Sistemas)* y el *Responsable Contable*.

---

4. LAS 4 "PREGUNTAS TRAMPA" QUE TE PUEDE HACER SORIA OJEDA MAÑANA SOBRE TU TP

Estudiate de memoria estas 4 respuestas porque van directo a los detalles finos de su trabajo:

1. **«En la tabla de costo-beneficio de la página 29, la fila de la Red VPN les da una pérdida o beneficio neto negativo de $-\$140.000$. ¿Por qué mantuvieron ese control si es más caro que la pérdida que evita?»**
   - *Tu respuesta:* «Lo discutimos en el grupo y lo dejamos documentado en la página 30 y en la tabla de acuerdos finales. Si bien el enlace redundante 4G/5G hace que la inversión ($\$1.100.000$) más el riesgo residual ($\$640.000$) supere en $\$140.000$ a la pérdida directa de la VPN ($\$1.600.000$), **decidimos sostener la inversión porque la conectividad VPN es la condición habilitante previa (Prioridad 1, RTO 2 hs)** para que puedan operar todos los demás sistemas centralizados en ECOM Chaco y las 5 delegaciones. Su justificación no es el ahorro directo en ese renglón, sino garantizar la disponibilidad de todo el resto del ERP y el GeoVial».
2. **«¿Por qué en el punto 3 clasificaron políticas que empiezan diciendo *"Está prohibido..."* como Permisivas, y las que dicen *"Sólo se permite..."* como Prohibitivas?»**

- *Tu respuesta:* «Porque aplicamos literalmente el criterio de la cátedra (pág. 27 del TP): en una **política permisiva**, todo lo que no está expresamente prohibido está permitido, por lo tanto se redacta enunciando puntualmente qué acción específica se prohíbe (*"Está prohibido fumar en el rack"*). En cambio, en una **política prohibitiva**, todo lo que no está expresamente permitido está denegado por defecto, por lo que se redacta enunciando taxativamente lo único que está autorizado (*"Sólo se permite el acceso mediante VPN con 2FA"*)».

3. **«¿Por qué en la tabla de la Fase II (pág. 13) el total de Pérdida Esperada suma** $25.865.000**, pero en la tabla de Costo-Beneficio (pág. 30) el total salta a** $26.765.000**?»**

    - *Tu respuesta:* «Esa diferencia exacta de $900.000 corresponde al activo **Instalaciones de Sede Central y Delegaciones (incendio, inundación y corte eléctrico)** que incorporamos en el punto 3.8. Al principio habíamos armado la tabla de la Fase II solo con las 6 amenazas lógicas y de robo, pero en la revisión grupal (documentada en la página 43) acordamos cuantificar e incorporar la amenaza física accidental sobre las instalaciones ($900.000) porque era indispensable para justificar el Nivel 5 de *Catástrofe* en el Plan de Contingencia».

4. **«Si ustedes fueran a auditar mañana el desarrollo *In-House* del ERP Vial que propusieron, ¿quién definiría los puntos de control según Lardent y quién haría la auditoría después?»**

    - *Tu respuesta:* «Según Lardent, durante el desarrollo del ERP Vial el auditor interno participa con un **rol activo y asesor** junto a nuestro *Departamento de Desarrollo de Soluciones* para definir los **puntos de control** (como la segregación de funciones en el Fondo Vial y las pistas de auditoría/logs inalterables). Pero, por el **principio deontológico de independencia y objetividad**, cuando el ERP Vial pase a producción en el Data Center de ECOM, la auditoría de sistema instalado **debe realizarla un auditor distinto** al que asesoró en el diseño de esos controles».

¡Con esto dominás tanto la teoría como cada rincón de tu TP! ¿Te queda alguna duda puntual de alguna página del trabajo o te sentís listo para mañana? ¡Muchísimos éxitos a vos y a todo el grupo!